Technical commitments: what the agreement should guarantee

Emily's email: Emily (10/30): the GOLD draft "spells out too many technical details and repeats much of the same language across the agreement, Appendix A, and system specifications attachment," and "goes beyond the NDPA in several areas, including annual independent audits and penetration testing, detailed record-access logging, specific patching and backup deletion deadlines, and AI provider restrictions as well as shorter time/limit on certain responses and requirements." Her recommendation: "the NDPA as the baseline, with a concise CHSS supplement where needed, stating each obligation once, and keeping implementation details in separate technical documentation." **Lewis County:** The Education Cooperative's eighteen-state NDPA (version 1.0 family), received 10/29: standard clauses Articles II, IV, and V, and the state terms for Colorado, Idaho, Iowa, New Hampshire, New York, Ohio, and Washington. **Columbus City DSA:** Columbus City Schools, Student Data Sharing Agreement, revised 3/17/2025, forwarded by James 10/30: services items 5 through 10 and the termination section. **District lens:** 1EdTech's Data Privacy and Security Agreement template (version 1.0, 2024), written by a task force of districts and suppliers including Fresno Unified, Scottsdale Unified, Albuquerque, and Loudoun County, and 1EdTech's Security Practices Rubric (version 1.0, 42 items). Both are public. A district that uses the 1EdTech template will hand CHSS that document in place of the NDPA. **Luke's decision:** Emily's structure is adopted. This page applies it clause by clause: for each technical commitment in the draft, who requires it, and whether it stays in the contract, moves to a district exhibit, moves to technical documentation, or comes out.

> **Purpose.** One question for each technical commitment in the agreement: how much should CHSS guarantee in the contract? The answer follows the structure Emily proposed on October 30: the NDPA as the baseline, a short CHSS supplement that states each obligation once, and implementation detail in separate technical documentation. The rows below are decided at the Tuesday, November 3 working session.

The rule

A commitment stays in the contract only if one of three tests is met:

1. **The NDPA already requires it.** Then it is not restated, and the supplement must not contradict it.
2. **A named district requires it in writing.** Then it goes in that district's one-page exhibit, in the district's own words, once Emily confirms CHSS can meet it.
3. **CHSS can evidence it today, or by a date it will put in the agreement.** Then it is stated once, in the supplement.

Everything else is technical documentation: dated, provided on request under the evidence clause, and not a contractual promise. Documentation is still read by districts, so it has to be accurate on the day it is given.

The decisions, row by row

Commitment as drafted	Who requires it	Recommendation
Annual independent assessment (SOC 2 Type II or equivalent)	**Columbus**, in writing. Not the NDPA; New York can require one after the fact.	**Columbus exhibit.** Out of the body. Emily decides what satisfies it: Azure's and Salesforce's SOC 2 Type 2 reports cover the hosting today; a CHSS assessment of its own configuration is a cost decision with a date.
Annual penetration test	Nobody in the first cohort. The 1EdTech template requires one.	**Technical documentation.** A district using the 1EdTech template takes it in its exhibit.
Record-level access logging, twelve-month retention, log data on request	**Columbus**, in writing; New Hampshire unless certified.	**One sentence in the supplement:** access is logged and log data is provided on request after an incident. Drop the retention period, the per-record detail, and the repeated sentence in 5.4.
Critical patches within seven days	**Columbus**: "within one week of release where reasonable and applicable."	**Columbus exhibit**, in Columbus's words. Out of the body.
Backups expire within ninety days, never restored	Nobody.	**Out.** Keep the NDPA's sixty-day disposition and one clause: backups are overwritten in the ordinary rotation and not restored to production.
AI commitments (a) through (i)	Colorado: no training on Student Data. Nobody else in writing.	**Keep four, move five.** Keep: no provider trains on Student Data; provider named; educators decide; notice before a provider changes. Move the rest to technical documentation and the privacy plan. The training sentence is a decision (next section).
Breach notice at seventy-two hours; family notice agreed within five business days; CHSS pays for its breach	NDPA: seventy-two hours. California: a described family-notice procedure.	**Keep seventy-two hours and the division of labor; drop the five-day clock.**
Deprovisioning within one business day; quarterly access review	Nobody.	**Technical documentation.**
Parent-request support within ten business days	California: a procedure, not a number.	**Keep**, as "promptly" unless Emily accepts ten days.
Feed-failure notice within one business day; validation report per load	Nobody; a service level.	**Onboarding guide.** Jonah has agreed to the support commitment itself.
Security questionnaire answered within thirty days	Common practice; the 1EdTech template uses thirty days.	**Keep.**

Commitment as drafted	Who requires it	Recommendation
Encryption in transit and at rest; MFA; SSO; hashed passwords; named framework	NDPA: a framework from Exhibit F. New York: NIST CSF. Columbus: hashed passwords and SSL.	**One sentence in the supplement**, naming NIST CSF, because CHSS can evidence it today on Azure and Salesforce. The rest of A.7's bullets go to documentation.
Background checks and annual training, coaches included	Six TEC states, for staff with direct student contact.	**Keep**, once Demian confirms current practice.
Incident response plan, maintained and tested	Implied by the framework; Columbus lists the steps.	**Keep as one clause.** Steps go to documentation.
U.S.-only storage and processing	**Columbus**; NDPA where state law requires.	**Keep as one sentence.**
Insurance: cyber $2M; general liability $1M/$2M; E&O $1M	**Columbus**: cyber $1M. 1EdTech template: general liability $1M/$3M.	**Keep**, at the limits Demian confirms.
Attachment 1, system specifications	Nobody.	**Out of the contract.** It becomes the first technical document.

Clause-by-clause detail: what the NDPA, Columbus, and the 1EdTech template each say

Commitment as drafted	NDPA (TEC eighteen-state)	Columbus City	1EdTech template
Annual independent assessment (A.7, A.13, Attachment 1)	Not required. Article V.2: the LEA may audit once a year on ten business days' notice. New York: the state Chief Privacy Officer may require an independent audit at the provider's expense, or accept an industry-standard audit report from the prior twelve months. New Hampshire: twenty-three listed controls, or annual evidence of a certification such as SOC 2 Type 2 or ISO 27001.	Item 7: "Third party audits of security operations are conducted annually."	Audit once per twelve months on thirty days' notice, or an annual audit summary or bridge letter (4.7).
Annual penetration test	Not required. New Hampshire control 16: periodically assess controls and correct deficiencies, or hold a certification.	Not required. James's recollection was audit, not penetration testing.	Required: a third-party penetration test within twelve months, with high and above

Commitment as drafted	NDPA (TEC eighteen-state)	Columbus City	1EdTech template
			findings remediated (4.7(a)).
Record-level access logging (A.7, 5.4)	Not in the standard clauses. New Hampshire controls 5 and 6: audit logs sufficient to investigate, and actions traceable to individual users, unless certified.	Item 8: "The identity of all persons having access to student data is documented and access is logged." Item 9: the District may request "log data for end user, administrative and maintenance activity."	Not in the body; the supplier's own standards are attached.
Critical patches within seven days (A.7)	Not required. New Hampshire control 20: correct flaws "in a timely manner," or a certification.	Item 7: "Deploy critical security patches within one week of release where reasonable and applicable."	Not required.
Backups expire within ninety days (A.10)	Not required. Article IV.6: disposition within sixty days of request; de-identified data exempt.	Destroy or return within ninety days of termination.	Ninety days after termination, thirty on request; a deletion certificate (4.9, Exhibit C).
AI commitments (A.12, A.6)	Not in the standard clauses. Colorado: "The Provider shall not use Student Data to train Artificial Intelligence (AI) models of systems." New Hampshire: no use for commercial product development; adaptive and customized learning permitted. Article IV.5: de-identified data may be used for "research and development of the Provider's educational sites, services, or applications."	Not addressed.	Not addressed in the agreement; the separate AI rubric asks whether prompts improve the model and where training data comes from.
Breach notice (A.8)	Required: seventy-two hours after confirmation (Article V.4); New York the same. Family notice is the LEA's; costs are not allocated.	The District "will be notified"; response steps listed; no fixed period.	Seventy-two hours (4.6).
Parent-request support (A.11)	Article II: the provider supports the LEA's response; no fixed period.	The parties "shall establish reasonable procedures."	Not addressed.

Commitment as drafted	NDPA (TEC eighteen-state)	Columbus City	1EdTech template
Encryption, MFA, SSO, passwords, framework (A.7)	Article V.3: a cybersecurity framework from Exhibit F. New Hampshire control 18: encryption at rest. New York: NIST CSF.	Item 6: salted hashes and SSL.	Framework alignment (NIST CSF, SOC 2, or ISO 27001) and no material decrease during the term (4.5(a)).
Background checks and training (A.7)	Article IV.3: confidentiality agreements for every employee with access. Six state terms: criminal background checks for employees with direct student contact.	Item 8: employees comply with FERPA.	Not addressed.
U.S. storage (A.9)	Article V.1: within the United States where required by law. New York: United States or Canada.	Item 5: no storage outside the United States without written consent.	Continental United States (3.2).
Insurance (A.14)	Not addressed.	Cyber liability of at least $1,000,000 covering crisis management, extortion, media and content, and security and privacy liability.	Exhibit E: cyber $1,000,000; general liability $1,000,000 per occurrence and $3,000,000 aggregate; carrier rated A or better by A.M. Best; institution as additional insured.
Disaster recovery plan (not in the draft)	Not required.	Not required.	Security rubric item DOC-05: tested annually.

The AI training clause (O21)

Jonah asked whether A.12(a) prevents CHSS from using the data to make Navigator smarter. It does, and it was written to: the phrase "Student Data, De-identified Data, or any output derived from them" closes the de-identify-then-train route, which is the first thing a district privacy officer checks. The decision is whether that is the position CHSS wants.

Position	What it means	Where it lands
1. Keep the clause as drafted.	No training on district data in any form. Navigator improves through evaluation and design, not through models trained on district data.	The strongest offer a district can receive. Gives up what the NDPA allows.

Position	What it means	Where it lands
2. Split the rule (recommended; drafted into v1.7).	No model is trained on Student Data or its outputs. CHSS may use De-identified Data, built and reviewed under A.10, for research and development of the Services, as long as the work stays inside CHSS and no provider receives it.	Permitted by NDPA Article IV.5 ("research and development of the Provider's educational sites, services, or applications"). Satisfies Colorado's ban, which covers Student Data only. Accepted by most districts when the review is documented and a minimum dataset size is stated.
3. Allow training on Student Data for CHSS-operated models.	Identifiable data trains the models.	Refused in Colorado under the TEC terms and in California under Exhibit G. Expect it to stop signature in several states.

Wording now in v1.7 (position 2). "(a) neither CHSS nor any Subprocessor will use Student Data, or any output derived from Student Data, to train, fine-tune, or otherwise improve any artificial-intelligence or machine-learning model, and neither will develop synthetic or inferred data from Student Data for any purpose other than delivering the Services to the District; this paragraph does not limit CHSS's use of De-identified Data and Aggregate Data, created and reviewed under A.10, for research and development of the Services and to demonstrate their effectiveness, including improving the on-track indicators, screeners, and intervention suggestions the Services provide, provided that this work stays within CHSS and no model provider or other Subprocessor receives or retains De-identified Data for it." The line is drawn at the model, not at the Services: nothing identifiable trains any model anywhere, and what CHSS learns from de-identified data stays inside CHSS.

Why each phrase is there, and two consequences for Tara

- "Neither CHSS nor any Subprocessor": the model provider is bound through CHSS, since a district cannot contract with the provider.
- "Student Data, De-identified Data, or any output derived from them": closes the de-identify-then-train route. California's NDPA version 1.5 (Exhibit G, clause 8) bars training and the development of synthetic or inferred data; Colorado's terms bar training on Student Data outright.
- "train, fine-tune, evaluate, or otherwise improve": evaluation sets are how models are tuned without "training" in name; the list prevents relabeling.
- "for any purpose other than delivering the Services": attaches to synthetic and inferred data, not to training. Clause (b) then permits the student-specific inferences Navigator produces, treated as Student Data.
- What the clause does not prevent: evaluating the program with de-identified and aggregate data (5.5, A.10); learning from results and encoding what works as rules, content, or configuration.
- No separate dataset floor: A.10 already requires the documented 34 C.F.R. § 99.31(b)(1) determination before any De-identified Data is retained, and suppresses cells under ten. The

1EdTech template's twenty-individual floor is an alternative if a district asks for a number.

- **For Tara, two consequences.** Most of the eighteen state terms, Ohio and Colorado among them, limit use to the services described in the NDPA's Exhibit A, so "evaluation and improvement of the Services using de-identified data" and the outcome measures she names must appear there. Iowa's terms say the NDPA "does not provide approval for use of Student Data for research or audit/evaluation purposes" and require the district's institutional review board approval first.

What goes where

Layer	Carries
NDPA (where executed)	Authorized use; employee obligations; no disclosure; de-identified data; sixty-day disposition; advertising limits; data storage; the audit right; the cybersecurity framework; seventy-two-hour breach notice; law-enforcement requests; subprocessor flow-down; the state terms.
CHSS supplement (Appendix A, about half its current length)	Coach access (5.1, 5.4). Permitted use, including no advocacy or political use (5.5). Screeners (6.7, A.15). Four AI commitments. Who notifies families after a breach and who pays (A.8). De-identified retention with the documented review and the twenty-student floor (A.10). One security sentence: framework, encryption, MFA, logging with log data on request, U.S. hosting on named providers. Evidence on request (A.13). Insurance (A.14). Immediate suspension and no automatic renewal (A.16). State terms (A.17). Order of precedence (5.2, A.18).
District exhibit (one page per district)	Anything a district adds, in its own words: section, original text, revised text. Columbus is the first entry.
Technical documentation (dated; provided on request under A.13; not contractual)	The control inventory (the twenty-five rows on the Notes tab, in the 1EdTech Security Practices Rubric's forty-two-item format); the system specifications now in Attachment 1; the deletion runbook; patch, backup, logging, and deprovisioning practice; penetration testing; disaster recovery; the hosting providers' SOC 2 Type 2 reports.

Where a district's state has an NDPA version, CHSS signs it (A.19). Where none exists, the NDPA's standard clauses are attached as the baseline exhibit, so the supplement never stands alone.

The Columbus exhibit, first draft

Each entry takes effect only if Emily confirms CHSS can meet it.

Section	Columbus requirement (rev. 3/17/2025)	Supplement text	Variation for Columbus
A.13	"Third party audits of security operations are conducted annually."	Evidence on request, once a year.	CHSS will provide annually the third-party audit reports covering the security operations of its hosting providers (SOC 2 Type 2 for Microsoft Azure and Salesforce) and [its own independent assessment once completed] [a documented annual review of its configuration].
A.7	"Deploy critical security patches within one week of release where reasonable and applicable."	In technical documentation.	Adopt Columbus's sentence verbatim.
A.7	Access documented and logged; log data on request.	One sentence, as recommended above.	None needed.
A.7	Salted and hashed passwords; SSL/HTTPS.	In technical documentation.	Adopt Columbus's sentence verbatim.
A.14	Cyber liability of at least $1,000,000.	$2,000,000, pending Demian.	None needed.
A.10	Destroy or return within ninety days.	Sixty days.	None needed; the supplement is stricter.
A.17	Comply with Ohio R.C. 3319.321, 3319.325 through 3319.327, and Chapter 1347 "as if it were the District."	Already in the Ohio bullet.	None needed.
A.5	Warrant COPPA conformity for data collected directly from students.	Not addressed.	Add: the Services collect no information online from children under thirteen; the screeners are administered by the District under 6.7.

What this means for the TEC form

- **Exhibit F:** the NIST Cybersecurity Framework, which New York requires in any case; exclusions listed in the attachment the form provides for.
- **New Hampshire:** the twenty-three listed controls or an annual certification. The technical documentation, in the rubric format, doubles as the New Hampshire attachment.
- **New York:** NIST alignment, the published Data Security and Privacy Plan, and the audit provision above.

- **Exhibit A:** add evaluation and improvement using de-identified data, and the outcome measures Tara names.

Tuesday, November 3

1. Confirm the three layers and the rule.
2. Decide each row of the table above.
3. Confirm the AI training clause as reworded in v1.7 (position 2), or revert to position 1.
4. Agree the format of the technical documentation (the rubric's forty-two items), who writes it, and the date of the first version. Confirm what CHSS can evidence today: tenant regions, encryption, MFA, the Azure and Salesforce SOC 2 Type 2 reports, the AI provider's name.
5. Confirm the TEC form answers: Exhibit F, the New Hampshire path, Schedule 1 accessibility documentation.
6. Set the date for the restructured draft to counsel.

Sources

- The Education Cooperative, eighteen-state NDPA for the Center for High School Success, originating district Lewis County C-1 (Missouri), received October 29, 2026.
- Columbus City Schools, Student Data Sharing Agreement, revised March 17, 2025.
- 1EdTech Consortium, Data Privacy and Security Agreement template v1.0 (2024), as published by Prince George's County Public Schools (https://www.pgcps.org/contentassets/0d463a5c451f40fcba26c2796d7a59c8/appendix-m-data-privacy-and-security-agreement.pdf); Security Practices Rubric v1.0 (https://www.imsglobal.org/spec/security-rubric/v1).
- California Education Code § 49073.1(b); Ohio Revised Code 3319.321, 3319.325 through 3319.327, and 1347.12; New York Education Law § 2-d and 8 NYCRR Part 121.
- The Arizona NDPA Exhibit G artificial-intelligence questionnaire; the California NDPA version 1.5 Exhibit G, clause 8.